System and identity

Amrutam Backend | Express.js + TypeScript | Phase 5 | 21 October 2026

Components and boundaries

A modular Express 5/strict TypeScript monolith runs API and worker as separate processes from one image. Routes bind controllers; controllers validate/map HTTP; services enforce workflows and policies; repositories own SQL. Constructor injection and the explicit composition root wire transaction-scoped repositories, crypto, Redis and clocks without a container or framework decorators. Audit owns its domain port; identity depends on the port rather than another module's repository.

Implemented modules: health, identity/security, bookings, doctor discovery and the audit adapter. Clinical notes, prescription versions, internal payments and admin compliance/analytics are implemented. The worker leases durable jobs and performs internal compensation. Component/data flow (diagrams/architecture.mmd), ER (diagrams/er.mmd), and implemented booking sequence (diagrams/booking-sequence.mmd) are kept distinct.

Identity and security data flow

Registration creates a pending patient, profile, hashed setup token and encrypted setup-delivery job atomically, returning a generic response. No email provider is configured; the audited operator CLI provides controlled manual setup delivery. Operator-only bootstrap is serialized and unavailable after the first admin.

Activation consumes the setup credential and returns an enrollment-only challenge. Password login likewise returns a challenge. TOTP enrollment supplies the approved URI once per logical operation; secrets are AES-GCM encrypted and bound to the user. Confirmation/verification conditionally consumes a timestep or recovery code and creates full sessions/tokens only after MFA. No ordinary DTO/log/audit contains seeds or credential hashes. See the security contract (identity-security.md).

JWT verification fixes algorithm/key/issuer/audience/type/lifetime. Every protected operation checks live role, status, auth version and session ownership/revocation. Privileged changes require recent MFA. Password/status changes and deactivation revoke sessions atomically. Refresh rotation retains all used hashes and reconciles short identical retries; independent reuse revokes the family. Redis enforces pre-authentication, endpoint, account and actor limits with no fail-open fallback. Trusted proxy addresses are explicit; forwarding headers are untrusted by default.

Persistence and correctness

Database and transaction guarantees

All eight PDF core tables remain, alongside ten supporting tables. Migration 0006 adds lifecycle activation, auth flows and refresh history without editing 0001–0005. Versioned SQL is checksum-protected and advisory-lock serialized, with each version in one transaction. Kysely over pg provides typed queries; pool, connection and SQL deadlines are bounded. Date/bigint types reflect actual PostgreSQL driver values.

The unit of work supplies repositories bound to the same connection/transaction. Identity changes, token/MFA state, audit and encrypted idempotency outcomes commit or roll back together. Expected security failures return outcomes so attempt counters and failure audits commit before HTTP error handling. External calls are excluded.

Database constraints reject overlapping doctor slots and multiple occupying consultations, bind slots/prescriptions to their doctor, protect historical/issued contents, and bind pending factors to their flow owner. Clinical notes and prescription payloads are AES-GCM encrypted with record-bound associated data. Database guards freeze completed clinical records and finalized prescriptions; authorized accesses are transactionally audited. Audit is monthly partitioned with a fallback and runtime append-only permissions.

The booking service locks/revalidates each slot and writes consultation, audit, idempotency and outbox together. Cancellation locks slot before consultation and releases occupancy atomically. Migration 0007 retains the exclusion/unique indexes, adds an INSERT guard and a database directory-cache generation. See booking policies and lock protocol (booking-and-discovery.md).

Caching and asynchronous work

Cache, jobs, retries and sagas

Redis supplies shared limits and public directory metadata caching, not authorization or appointment truth. Directory generation is updated transactionally in PostgreSQL; time-filtered discovery is uncached. Cache failures fall back to DB, while security enforcement still fails closed. Aggregate caching remains future work. Transactional outbox consumers use SKIP LOCKED leases, owner/attempt fencing, durable receipts, exponential backoff with jitter and terminal failure visibility. A separately scheduled, function-only maintenance identity creates upcoming monthly audit partitions and removes bounded expired security rows after a seven-day grace, preserving audit and clinical history. Partition fallback conflicts are reported for owner review without deleting rows.

Local PostgreSQL workflows do not require distributed sagas. The internal refund/compensation boundary uses durable jobs and a deterministic fake adapter called outside SQL transactions. Crash/retry/duplicate handling is tested; a real provider and its reconciliation remain unimplemented. No live payment gateway is required or implemented. Clinical partitioning awaits measurement to preserve global booking constraints; monthly audit partition maintenance is implemented without automatic audit deletion.

Detailed runbooks: docs/operations.md and docs/backup-dr.md. Mermaid sources: docs/diagrams/architecture.mmd, er.mmd and booking-sequence.mmd. These source diagrams are part of the architecture submission.

Deployment and evidence

Deployment, operations and evidence

Compose runs PostgreSQL 17, Redis, an owner migrator, restricted API and restricted worker identities. Application containers run non-root with read-only filesystems; worker/migrator receive no auth keys. Worker SQL privileges exclude clinical contents, prescriptions, users and audit history. Production mode requires verified database and Redis TLS. Build-only optional CA mounts preserve TLS validation and never enter runtime layers. No paid cloud resources are provisioned.

Structured redacted logs, request IDs, readiness/liveness and graceful shutdown exist. CI defines formatting/lint/type/build/contract/tests/dependency audit, Compose validation and image build. Hosted execution and delivery are not verified. Allowlisted OpenTelemetry spans cover actual HTTP requests, Kysely SQL operations and worker handling with traceparent persisted in the outbox. Prometheus-compatible metrics cover latency, conflicts, auth denials, pool pressure and queue health. Local collector/Prometheus/Tempo/Grafana and alerts are configured. Terraform specifies private ECS services, managed Multi-AZ PostgreSQL, replicated cache, KMS, secrets references, private ECR/endpoints and OIDC-gated deployment. No cloud resources or hosted delivery have been exercised. See `operations.md`, `backup-dr.md` and `infra/terraform/README.md` (from repository root) for operational boundaries.

Targets remain 100k consultations/day, p95 reads below 200 ms, writes below 500 ms, and 99.95% availability. A short local historical-fixture performance sample and logical backup restore drill supply limited evidence; sustained load, production failure and PITR tests remain open. Backup/DR objectives remain PITR RPO 5 minutes/RTO 60 minutes and copied-backup regional RPO 24 hours/RTO 4 hours, all unverified. Regional recovery can exceed the monthly availability budget. The checklist (implementation-checklist.md) retains these and every other original PDF deliverable.

Phase 4 policies, exact state machines, analytics freshness/utilization semantics and worker crash/retry boundaries are documented in clinical/payments/jobs (clinical-payments-jobs.md).

Phase 5 deployment flow

GitHub checks validate code, migration lifecycles, OpenAPI, secrets, dependencies, Terraform, alerts, workflows and container images. A separately approved main-only staging workflow obtains short-lived OIDC credentials, scans/publishes an immutable image, runs an owner migration task, rolls restricted API/worker tasks and performs smoke checks. Failure restores prior task revisions, with forward schema repair reviewed independently. Hourly maintenance runs through a separate function-only SQL role. Application tasks receive no owner credentials; workers cannot decrypt clinical records. Cloud validation remains a pre-production gate.